ISO 27001
Plan de Auditoría Interna

SPIKA TECH S.L

CyberXia Security

[marzo 2025 – Plan de Auditoría Interna]

Cláusula de Confidencialidad

La presente documentación es propiedad de CyberXia Security y tiene carácter Confidencial. No podrá ser objeto de reproducción total o parcial, tratamiento informático ni transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, registro o cualquiera otro. Asimismo, tampoco podrá ser objeto de préstamo, alquiler o cualquier forma de cesión de uso sin el permiso previo y por escrito de CyberXia Security. El incumplimiento de las limitaciones señaladas por cualquier persona que tenga acceso a la documentación podrá ser perseguido conforme a ley. A requerimiento de CyberXia Security deberán ser devueltas todas las copias de este documento, junto con la confirmación de no haber conservado ninguna copia del documento o su contenido.

© CyberXia Security, S.L.

Índice

1 DATOS DEL PLAN DE AUDITORÍA 4
2 CONTROL DE CAMBIOS 5
3 CONFIDENCIALIDAD Y DEBER DE SECRETO 6
4 OBJETIVO DE LA AUDITORÍA 7
5 ALCANCE DE LA AUDITORÍA 8
6 INFORMACIÓN SOBRE LA AUDITORÍA 8
7 METODOLOGÍA DE LA AUDITORÍA 10
7.1 Tipos de hallazgos 10
8 PLANIFICACIÓN DE LA AUDITORÍA 11
8.1 Fase de estudio documental previo 11
8.1.1 Día 12/03/2025 11
8.2 Fase de auditoría interna 11
8.2.1 Día 14/03/2025 11
8.2.2 Día 17/03/2025 12

1 Datos del Plan de Auditoría

Grupo Auditor:	Carlos Gómez Pintado- Consultor de ciberseguridad CyberXia Security S.L Carlos Castillo Sanjuan - Consultor de ciberseguridad CyberXia Security S.L
Entidad destino / Propietario:	SPIKA TECH
Título:	Plan Auditoría Interna ISO 27001 – SPIKA TECH
Versión:	1.0
Autor:	Ciberseguridad – CyberXia Security S.L
Lista de Distribución	Alta Dirección

Control de Firmas

Autores:	Revisado por:	Aprobado por:
Carlos Gómez Pintado Carlos Castillo Sanjuan CyberXia Security S.L.	Carlos Gómez Pintado Carlos Castillo Sanjuan CyberXia Security S.L.	GOMEZ PINTADO CARLOS - 51146837N Firmado digitalmente por GOMEZ PINTADO CARLOS - 51146837N Fecha: 2025.03.19 00:02:02 +01'00' CyberXia Security S.L.

2 Control de cambios

Versión del documento	Cambios realizados
1.0 – 19/03/2025	Versión inicial del documento.

3 Confidencialidad y deber de secreto

Cyberxia, S.L, (en adelante entidad auditora), con plena libertad ha aceptado el cargo de SPIKA TECH S.L para realizar el presente informe de diagnóstico del grado de cumplimiento con los requisitos de la norma **ISO 27001:2022**, identificando las deficiencias y proponiendo, en su caso, medidas correctoras o complementarias necesarias.

Los resultados expuestos en este informe se corresponden con la investigación muestras realizada por el equipo auditor, por lo que no se descarta la aparición de nuevas desviaciones en auditorías posteriores, ya sean internas o de certificación, llevadas a cabo por el mismo equipo auditor u otro distinto nombrado y contratado por SPIKA TECH S.L.

El equipo de auditoría implicado en la realización del presente informe garantiza que este ha sido realizado bajo los criterios de independencia, imparcialidad y objetividad, y sin otras limitaciones que las impuestas por la ley, normas éticas o deontológicas.

La entidad auditora declina cualquier responsabilidad derivada de falsedades o aportaciones erróneas por parte del auditado, así como de la falta de éstas tras haber sido debidamente solicitadas.

Asimismo, la entidad auditora ha acometido este encargo atendiéndose a las exigencias técnicas, deontológicas, y éticas adecuadas a la tutela de dicho asunta, habiéndose apoyado para ello en sus colaboradores, quienes han actuado bajo su responsabilidad, guardando el mismo nivel de secreto y con las mismas exigencias técnicas, deontológicas y éticas.

Queda por tanto bajo la responsabilidad de éste informar a su vez de cuantos terceros, internos o externos, pudieran tener un interés legítimo en la presente auditoría.

4 Objetivo de la Auditoría

El objetivo de la realización de la auditoría es la verificación del nivel de implementación, mantenimiento y mejora del Sistema de Seguridad de la Información (SGSI) a través de los siguientes puntos:

- Evaluar la conformidad y el grado de cumplimiento con los requisitos de la norma UNE – ISO/IEC 27001:2023.
- Evaluar el grado de comprensión de los requisitos por parte del personal de la organización.
- Revisar la adecuación de la documentación del sistema definido por la organización.
- Verificar el grado de confianza que merece el sistema auditado sobre el nivel de seguridad implantado, tanto internamente como frente a terceros que pudieran estar relacionados, es decir, evaluar la capacidad de la organización para garantizar la confidencialidad, disponibilidad e integridad de la información mediante la aplicación del proceso de gestión del riesgo.

5 Alcance de la Auditoría

El alcance de la auditoría se centra en la evaluación del Sistema de Gestión de Seguridad de la Información (SGSI) implementado por SPIKA TECH S.L con el fin de verificar su conformidad con los requisitos de la norma ISO/IEC 27001:2013.

El Alcance acordado y, por ende, aquél que ha sido auditado, corresponde al Sistema de Gestión de Información que soporta los servicios instrumentales[1] y finalistas[2] de SPIKA TECH S.L.

Es decir, se han auditado todos los aspectos de seguridad de la información relacionados con todos los servicios prestados por SPIKA TECH S.L, siendo el principal de ellos el desarrollo de software para otras organizaciones y entidades.

---

1 Aquel servicio considerado como necesario para poder prestar un servicio finalista (recursos humanos, gestión de nóminas, etc).

2 Aquel servicio prestado directamente al cliente o usuario final.

6 Información sobre la auditoría

Fecha de realización	Fecha de estudio de documentación previa: 12/03/2025. Fecha de auditoría en modo "remoto": 14/03/2025. 17/03/2025.
Ubicaciones	Auditoría realizada por "videoconferencia".
Datos del equipo de auditoría	Carlos Gómez Pintado [CGP] Carlos Castillo Sanjuan – [CCS]
Personal entrevistado / Interviniente en nombre del SPIKA TECH	David Pozo Sánchez [Responsable del SGSI y jefe de seguridad suplente] Carlos Zúñiga Arnau [CEO y jefe de seguridad] Carlos Rodrigo Rivero [CIO y responsable de IT] Fernando Pozo Ocampo [COO y RRHH]
Tipo de revisión	**Auditoría Interna considerando los requisitos de la norma UNE ISO/IEC 27001:2023.**

FUNCIONES DE LOS AUDITORES:

- Programar y planificar la auditoría.
- Dirigir la reunión inicial y final.
- Liderar y desarrollar la auditoría.
- Recopilación de evidencias de auditoría y registros asociados.
- Preparación de las conclusiones en base a los hallazgos documentados de auditoría que resumen la conformidad del sistema.

Las organizaciones privadas han venido desarrollando sistemas de gestión, sobre la base de normas estandarizadas. Estos sistemas establecen procesos y mecanismos de funcionamiento de las propias entidades, según el alcance seleccionado, que pueden considerar medidas de seguridad, y de protección de activos e información.

7 Metodología de la Auditoría

El proceso de auditoría se llevará a cabo a través de los siguientes métodos:

- Revisión de la documentación aportada/ mostrada del Sistema de Gestión.
- Entrevistas mantenidas con personal dentro del alcance de la auditoría.
- Comprobaciones realizadas in situ, en las instalaciones de SPIKA TECH S.L.
- Comprobaciones realizadas de manera remota.

7.1 Tipos de hallazgos

A lo largo del presente informe se han incorporado previsiones relacionadas con la potencial desviación que puede existir en el sistema, con respecto a la norma que se está analizando, y pueden consistir en:

- **Conformidad:** No se hace mención por no haberse detectado desviación o incumplimiento, en base a las evidencias, revisiones, entrevistas o análisis realizado.
- **No conformidad (NC):** Implica que existe un incumplimiento, pudiendo ser:
    - **NCm:** Algún requisito de la norma de referencia no se está cumplimiento total o parcialmente, pero que no represente un riesgo grave para el desempeño del SGSI.
    - **NCM:** Incumplimiento total de uno o varios requisitos que implica un grave riesgo para el desempeño del SGSI y la seguridad de la organización.
- **Observación (OBS):** Representa un incumplimiento potencial de un requisito a juicio del auditor, y caso de no ponerse en remedio en un corto plazo de tiempo podría derivar en una "no conformidad".
- **Oportunidad de Mejora (OM):** Aunque la organización cumple el mínimo exigido por la medida examinada, bajo criterios objetivos de seguridad, existe un margen de mejora para optimizar el proceso, una actividad o una tarea concreta relacionada.
- **No aplica (N/A):** El requisito no es aplicable.
- **No auditado[()]:** El requisito no se ha auditado.

8 Planificación de la Auditoría

8.1 Fase de estudio documental previo

8.1.1 Día 12/03/2025

Revisión previa de la documentación aportada por el cliente y requerida por el equipo auditor (no requiere presencia del personal de SPIKA TECH S.L.

8.2 Fase de auditoría interna

8.2.1 Día 14/03/2025

Hora:	Auditor /es	Área / Responsable	Puntos a revisar
9:00 – 9:15	CGP CCS	Responsable del SGSI	**Reunión inicial. Consideraciones generales:** • Explicación del proceso de auditoría. • Revisión y confirmación del Plan de Auditoría.
9:15 – 10:30	CGP CCS	Responsable del SGSI	**Reunión inicial. Consideraciones generales:** • Alcance y contexto. • Revisión de No conformidades y Observaciones de auditorías previas. • Informe de revisión por la dirección. • Objetivos de seguridad de la información. • Análisis de Riesgos y Plan de Tratamiento de Riesgos. • Indicadores y métricas.
10:30 -12:00	CGP CCS	Responsable del SGSI Responsable de RRHH.	• Controles relacionados con la capacidad operativa Gobierno: 5.1, 5.2, 5.3, 5.4, 5.5, 5.6 y 5.8. • Controles relacionados con la capacidad operativa "Seguridad de los recursos humanos": 6.1, 6.2, 6.3, 6.4, 6.5, 6.6 y 6.7.
PAUSA			

12:30 -13:00	CGP CCS	Responsable del SGSI Responsable de TI	• Controles relacionados con la capacidad operativa "Gestión de identidad y accesos": 5.15, 5.16, 5.17, 5.18, 8.2, 8.3, 8.4, 8.5.
12:30 -15:00	CGP CCS	Responsable del SGSI Responsable de TI / otros responsables necesarios	• Controles relacionados con la capacidad operativa "Gestión de identidad y accesos": 5.15, 5.16, 5.17, 5.18, 8.2, 8.3, 8.4, 8.5. • Controles relacionados con la capacidad operativa "Gestión de activos": 5.9, 5.10, 5.11, 8.1. • Controles relacionados con la capacidad operativa "Seguridad física": 7 al 7.14.
FIN DE LA JORNADA			

8.2.2 Día 17/03/2025

Hora:	Auditor /es	Área / Responsable	Puntos a revisar
9:00 – 10:30	CGP CCS	Responsable del SGSI	• Controles relacionados con la capacidad operativa "Protección de la información": 5.12, 5.13, 5.14, 5.33, 5.34, 8.7, 8.10, 8.11, 8.12, 8.33. • Controles relacionados con la capacidad operativa "Legal y cumplimiento": 5.31, 5.32, 5.36. • Controles relacionados con la capacidad operativa "Legal y cumplimiento": 5.31, 5.32, 5.36. • Controles relacionados con la capacidad operativa "Garantía de seguridad de la información": 5.35.
10:30 – 12:00	CGP CCS	Responsable del SGSI	• Controles relacionados con la capacidad operativa "Gestión de eventos de seguridad de la información": 5.24 a 5.28, 6.8, 8.15, 8.16 y 8.17. • Controles relacionados con la capacidad operativa "Seguridad de sistemas y redes": 8.20 a 8.23. • Controles relacionados con la capacidad operativa "Gestión de amenazas y vulnerabilidades": 5.7 y 8.8

PAUSA			
12:30 -13:00	CGP CCS	Responsable del SGSI Responsable de TI	• Controles relacionados con la capacidad operativa "Seguridad de aplicaciones": 8.18, 8.19, 8.25 a 8.32 y 8.34. • Controles relacionados con la capacidad operativa "Configuración segura" 8.9 y 8.24.
12:30 -15:00	CGP CCS	Responsable del SGSI Responsable de TI / otros responsables necesarios	• Controles relacionados con la capacidad operativa "Continuidad" 5.29, 5.30, 5.37, 8.6, 8.13 y 8.14. • Controles relacionados con la capacidad operativa "Seguridad en la relación con los proveedores" 5.19 a 5.23
FIN DE LA JORNADA			

CyberXia Security S.L.

C/ Serrano 8, 3izq, 28001 Madrid, Madrid

http://cyberxiasec.com